



HACKTHEBOX



Wrong Spooky Season

30th November 2022 / Document No. D22.102.203

Prepared By: c4n0pus

Challenge Author(s): c4n0pus

Difficulty: **Very Easy**

Classification: Official

Synopsis

Wrong Spooky Season is a very easy forensic challenge focusing on `pcap` analysis to retrieve the flag. Players are provided with a capture file that contains traffic from `CVE-2022-22965` exploit. They will have to explore the traffic, figure out what commands the attacker has executed, and after which, examine the reverse shell connection.

Description

"I told them it was too soon and in the wrong season to deploy such a website, but they assured me that theming it properly would be enough to stop the ghosts from haunting us. I was wrong." Now there is an internal breach in the `Spooky Network` and you need to find out what happened. Analyze the the network traffic and find how the scary ghosts got in and what they did.

Skills Required

General Understanding of Computer Science

Skills Learned

- PCAP Statistics
- Basic Wireshark

Enumeration

We are given a pcap file named `capture.pcap` containing suspicious traffic and tasked to analyze it. Upon opening it up in Wireshark we see a lot of `GET` requests suggesting that the attacker visits the website.

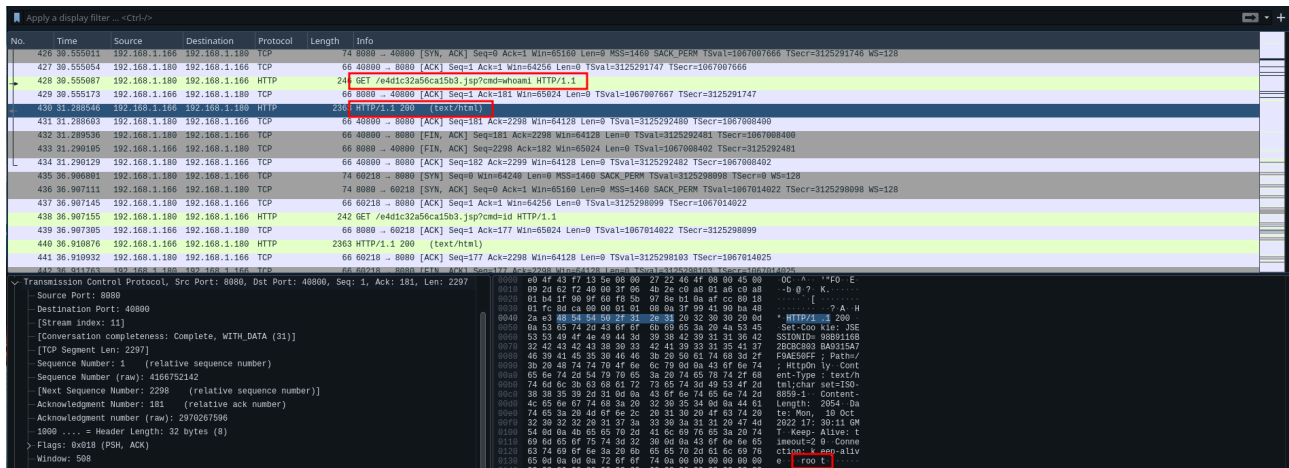
No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.1.180	192.168.1.166	TCP	74	53500 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3125261192 TSecr=0 WS=128
2	0.000020	192.168.1.166	192.168.1.180	TCP	74	8080 → 53500 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=1066977097 TSecr=3125261192 WS=128
3	0.001004	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3125261193 TSecr=1066977097
4	0.001066	192.168.1.180	192.168.1.166	HTTP	560	GET /spookhouse/home HTTP/1.1
5	0.001262	192.168.1.166	192.168.1.180	TCP	66	8080 → 53500 [ACK] Seq=1 Ack=495 Win=64768 Len=0 TSval=1066977098 TSecr=3125261193
6	0.285290	192.168.1.166	192.168.1.180	TCP	7306	8080 → 53500 [PSH, ACK] Seq=1 Ack=495 Win=64768 Len=7240 TSval=1066977382 TSecr=3125261193 [TCP segment of a reassembled PDU]
7	0.285333	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=495 Ack=7241 Win=61312 Len=0 TSval=3125261477 TSecr=1066977382
8	0.285357	192.168.1.166	192.168.1.180	TCP	1818	8080 → 53500 [PSH, ACK] Seq=7241 Ack=495 Win=64768 Len=952 TSval=1066977382 TSecr=3125261193 [TCP segment of a reassembled PDU]
9	0.285361	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=495 Ack=8193 Win=60544 Len=0 TSval=3125261477 TSecr=1066977382
10	0.285366	192.168.1.166	192.168.1.180	TCP	4648	8080 → 53500 [PSH, ACK] Seq=8193 Ack=495 Win=64768 Len=4577 TSval=1066977382 TSecr=3125261193 [TCP segment of a reassembled PDU]
11	0.285371	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=495 Ack=12770 Win=50320 Len=0 TSval=3125261477 TSecr=1066977382
12	0.286522	192.168.1.166	192.168.1.180	HTTP	71	HTTP/1.1 200 (text/html)
13	0.286547	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=495 Ack=12770 Win=50320 Len=0 TSval=3125261478 TSecr=1066977383
14	0.340655	192.168.1.180	192.168.1.166	HTTP	525	GET /spookhouse/css/styles.css HTTP/1.1
15	0.341061	192.168.1.166	192.168.1.180	TCP	66	8080 → 53500 [ACK] Seq=12775 Ack=954 Win=64384 Len=0 TSval=1066977430 TSecr=3125261532
16	0.368205	192.168.1.166	192.168.1.180	TCP	8258	8080 → 53500 [PSH, ACK] Seq=12775 Ack=954 Win=64384 Len=8192 TSval=1066977465 TSecr=3125261532 [TCP segment of a reassembled PDU]
17	0.368279	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=954 Ack=20067 Win=57216 Len=0 TSval=3125261560 TSecr=1066977465
18	0.368359	192.168.1.166	192.168.1.180	TCP	8258	8080 → 53500 [PSH, ACK] Seq=20067 Ack=954 Win=64384 Len=8192 TSval=1066977465 TSecr=3125261532 [TCP segment of a reassembled PDU]
19	0.368375	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=954 Ack=20150 Win=64384 Len=0 TSval=3125261560 TSecr=1066977465
20	0.368391	192.168.1.166	192.168.1.180	TCP	8258	8080 → 53500 [PSH, ACK] Seq=20150 Ack=954 Win=64384 Len=8192 TSval=1066977465 TSecr=3125261532 [TCP segment of a reassembled PDU]
21	0.368400	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=954 Ack=37351 Win=40932 Len=0 TSval=3125261560 TSecr=1066977465
22	0.368513	192.168.1.166	192.168.1.180	TCP	18890	8080 → 53500 [PSH, ACK] Seq=37351 Ack=954 Win=64384 Len=18824 TSval=1066977465 TSecr=3125261560 [TCP segment of a reassembled PDU]
23	0.368533	192.168.1.180	192.168.1.166	TCP	8258	[TCP Previous segment not captured] 8080 → 53500 [PSH, ACK] Seq=61927 Ack=954 Win=64384 Len=8192 TSval=1066977465 TSecr=3125261560 [TCP segment of a reassembled PDU]
24	0.368540	192.168.1.180	192.168.1.166	TCP	78	53500 → 8080 [ACK] Seq=954 Ack=56175 Win=22016 Len=0 TSval=3125261560 TSecr=1066977465 SLE=61927 SRE=70119
25	0.368548	192.168.1.166	192.168.1.180	TCP	5616	[TCP Out-of-Order] 8080 → 53500 [PSH, ACK] Seq=56175 Ack=954 Win=64384 Len=5616 TSval=1066977465 TSecr=3125261560 [TCP segment of a reassembled PDU]
26	0.368555	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=954 Ack=70119 Win=15744 Len=0 TSval=3125261560 TSecr=1066977465
27	0.368560	192.168.1.166	192.168.1.180	TCP	8130	8080 → 53500 [PSH, ACK] Seq=70119 Ack=954 Win=64384 Len=8064 TSval=1066977465 TSecr=3125261560 [TCP segment of a reassembled PDU]
28	0.368564	192.168.1.180	192.168.1.166	TCP	7745	[TCP Window Shift] 8080 → 53500 [PSH, ACK] Seq=64143 Ack=954 Win=64384 Len=7680 TSval=1066977465 TSecr=3125261560 [TCP segment of a reassembled PDU]
29	0.369795	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=954 Ack=85083 Win=64128 Len=0 TSval=3125261561 TSecr=1066977465
30	0.370183	192.168.1.166	192.168.1.180	TCP	31922	8080 → 53500 [PSH, ACK] Seq=85083 Ack=954 Win=64384 Len=31856 TSval=1066977467 TSecr=3125261561 [TCP segment of a reassembled PDU]
31	0.370174	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=954 Ack=117719 Win=110336 Len=0 TSval=3125261562 TSecr=1066977467
32	0.370248	192.168.1.166	192.168.1.180	TCP	31922	8080 → 53500 [PSH, ACK] Seq=117719 Ack=954 Win=64384 Len=31856 TSval=1066977467 TSecr=3125261561 [TCP segment of a reassembled PDU]
33	0.370286	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=954 Ack=149575 Win=110336 Len=0 TSval=3125261562 TSecr=1066977467
34	0.370356	192.168.1.166	192.168.1.180	TCP	31922	8080 → 53500 [PSH, ACK] Seq=149575 Ack=954 Win=64384 Len=31856 TSval=1066977467 TSecr=3125261562 [TCP segment of a reassembled PDU]
35	0.370381	192.168.1.180	192.168.1.166	TCP	66	53500 → 8080 [ACK] Seq=954 Ack=182431 Win=110336 Len=0 TSval=3125261562 TSecr=1066977467

We could clean up the displayed packets by applying an `http` filter to show only the `http` requests rather than their `TCP` packets as well.

Looking a bit further down, we see some suspicious `POST` requests which contain a rather strange body:

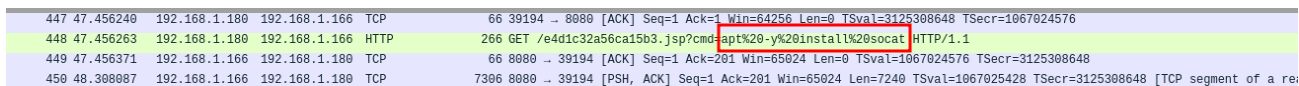
The image shows a Wireshark packet capture of a suspicious POST request. The packet list pane shows a POST request to `/spookhouse/home/ HTTP/1.1` with a length of 775 bytes. The packet details pane shows the request body as a URL-encoded string: `application/x-www-form-urlencoded`. The packet bytes pane shows the raw data of the request body, which is a URL-encoded string: `ie (%775 bytes)`. The packet list pane shows the request as a POST to `/spookhouse/home/ HTTP/1.1` with a length of 775 bytes. The packet details pane shows the request body as a URL-encoded string: `application/x-www-form-urlencoded`. The packet bytes pane shows the raw data of the request body, which is a URL-encoded string: `ie (%775 bytes)`.

Following the strange requests, we can see the attacker has gained `RCE` on the server!

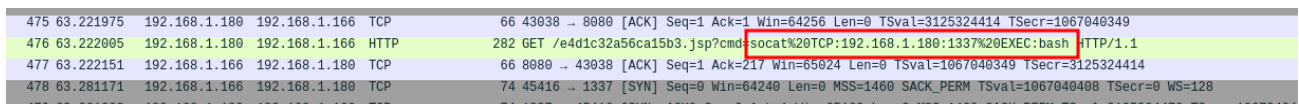


Evidently (not getting into details), the suspicious `POST` requests are the exploit for the `CVE-2022-22965` vulnerability.

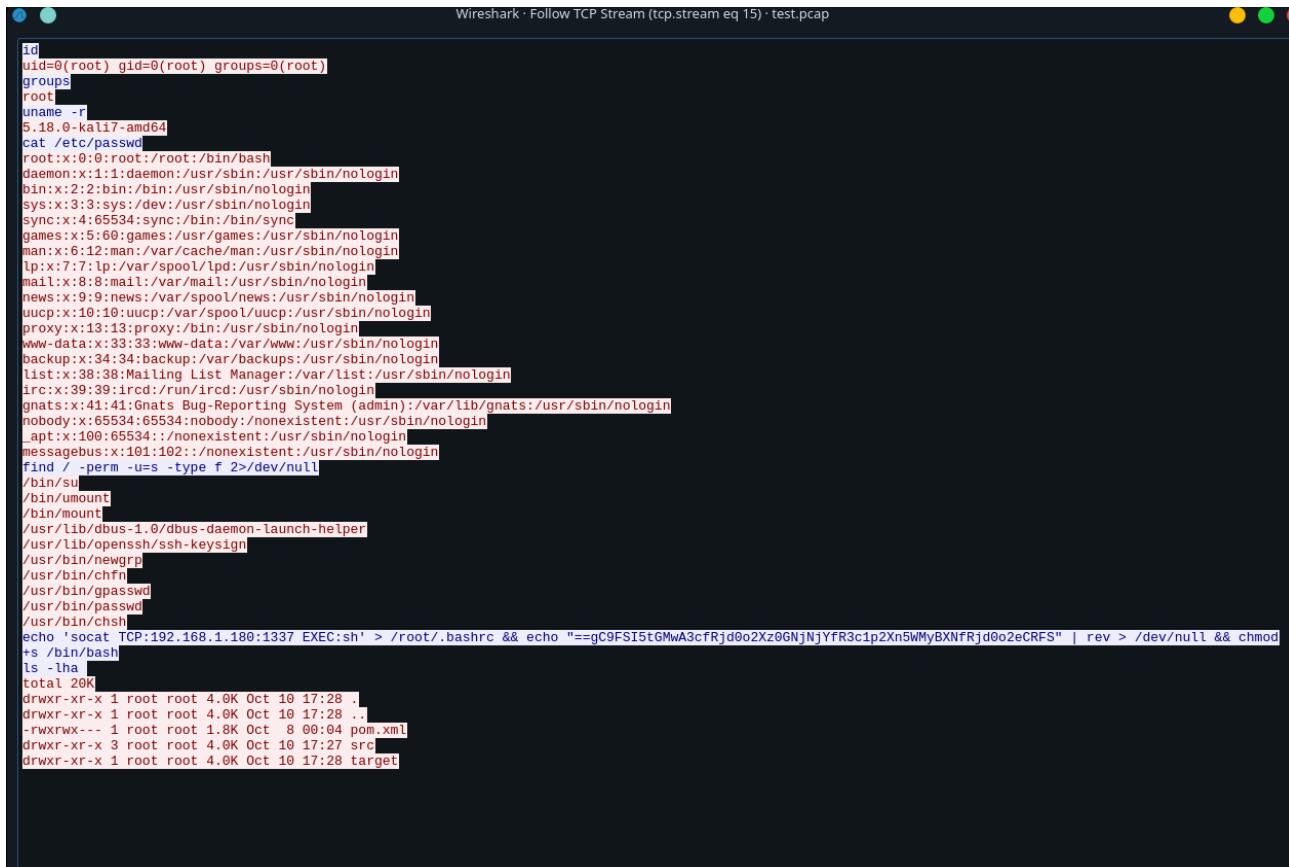
A couple of lines and some minor enumeration later, we can see the attacker installs `socat`



After installing `socat`, the attacker initiates a reverse connection using `bash`



We know the port of the reverse shell so that we can apply a filter `tcp.port == 1337` on that `TCP` port and recover the traffic:



Alternative Path

Rather than analyzing the whole capture, we could head to **Statistics -> Conversations -> TCP**. Observing the connections, we can conclude that since the server is `192.168.1.166` and the attacker is `192.168.1.180` if the server is connecting back to the attacker's machine (which it does), then we are most probably looking for some reverse shell:

Ethernet · 1		IPv4 · 1		IPv6		TCP · 15		UDP						
Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
192.168.1.166	45416	192.168.1.180	1337	26	3.362 KiB	14	12	2.205 KiB	14	1.157 KiB	63.281171	37.0519	487 bytes	255 bytes
192.168.1.180	39194	192.168.1.166	8080	28	62.363 KiB	12	15	1.170 KiB	13	61.193 KiB	47.455999	1.9197	4.875 KiB	255.011 KiB
192.168.1.180	40800	192.168.1.166	8080	10	3.079 KiB	10	6	584 bytes	4	2.509 KiB	30.554747	0.7354	6.204 KiB	27.292 KiB
192.168.1.180	43038	192.168.1.166	8080	7	694 bytes	13	4	488 bytes	3	206 bytes	63.221662	30.0710	129 bytes	54 bytes
192.168.1.180	53484	192.168.1.166	8080	18	13.948 KiB	9	10	976 bytes	8	12.995 KiB	15.445106	0.0045		
192.168.1.180	53500	192.168.1.166	8080	129	540.403 KiB	0	63	5.949 KiB	66	534.454 KiB	0.000000	66.3270	734 bytes	64.463 KiB
192.168.1.180	53506	192.168.1.166	8080	31	139.583 KiB	1	14	1.409 KiB	17	138.174 KiB	0.429023	65.8979	175 bytes	16.773 KiB
192.168.1.180	53510	192.168.1.166	8080	30	108.561 KiB	2	13	1.345 KiB	17	107.216 KiB	0.429523	65.8975	167 bytes	13.016 KiB
192.168.1.180	53522	192.168.1.166	8080	17	18.805 KiB	3	9	1.088 KiB	8	17.717 KiB	0.430095	65.8969	135 bytes	2.150 KiB
192.168.1.180	53530	192.168.1.166	8080	101	1.093 MiB	4	49	4.576 KiB	52	1.088 MiB	0.430435	67.6066	554 bytes	131.855 KiB
192.168.1.180	53546	192.168.1.166	8080	46	302.215 KiB	5	22	1.932 KiB	24	300.283 KiB	0.436189	65.8907	240 bytes	36.458 KiB
192.168.1.180	59854	192.168.1.166	8080	18	13.956 KiB	6	10	984 bytes	8	12.995 KiB	9.341013	0.0847	90.791 KiB	1.199 MiB
192.168.1.180	59858	192.168.1.166	8080	18	14.570 KiB	7	10	1.575 KiB	8	12.995 KiB	9.425774	0.0065	1.907 MiB	15.733 MiB
192.168.1.180	59860	192.168.1.166	8080	16	13.717 KiB	8	9	805 bytes	7	12.931 KiB	13.436945	0.0053	1.163 MiB	19.133 MiB
192.168.1.180	60218	192.168.1.166	8080	10	3.075 KiB	11	6	580 bytes	4	2.509 KiB	36.906801	0.0056	815.853 KiB	3.529 MiB

We can right-click on the conversation in question and apply it as a filter:

Ethernet · 1		IPv4 · 1		IPv6		TCP · 15		UDP						
Address A	Port A	Address B	Port B											
192.168.1.166	45416	192.168.1.180	1337	Apply as Filter	Selected	Filter on stream id	57 KIB	63.281171	37.0519	487 bytes	255 bytes			
192.168.1.180	39194	192.168.1.166	8080	Prepare as Filter	Not Selected	A ↔ B	93 KIB	47.455999	1.9197	4.875 KiB	255.011 KiB			
192.168.1.180	40800	192.168.1.166	8080	Find	...and Selected	A → B	09 KIB	30.554747	0.7354	6.204 KiB	27.292 KiB			
192.168.1.180	43038	192.168.1.166	8080	Colorize	...or Selected	B → A	bytes	63.221662	30.0710	129 bytes	54 bytes			
192.168.1.180	53484	192.168.1.166	8080	Copy Conversation table	...and not Selected	A ↔ Any	095 KIB	15.445106	0.0045					
192.168.1.180	53500	192.168.1.166	8080	Resize all columns to content	...or not Selected	A → Any	454 KIB	0.000000	66.3270	734 bytes	64.463 KiB			
192.168.1.180	53506	192.168.1.166	8080		14	1.409	Any → A	174 KIB	0.429023	65.8979	175 bytes	16.773 KiB		
192.168.1.180	53510	192.168.1.166	8080	30	108.561 KiB	2	13	1.345	Any ↔ B	216 KIB	0.429523	65.8975	167 bytes	13.016 KiB
192.168.1.180	53522	192.168.1.166	8080	17	18.805 KiB	3	9	1.088	Any → B	17 KIB	0.430095	65.8969	135 bytes	2.150 KiB
192.168.1.180	53530	192.168.1.166	8080	101	1.093 MiB	4	49	4.576	B → Any	38 MiB	0.430435	67.6066	554 bytes	131.855 KiB
192.168.1.180	53546	192.168.1.166	8080	46	302.215 KiB	5	22	1.932		283 KIB	0.436189	65.8907	240 bytes	36.458 KiB
192.168.1.180	59854	192.168.1.166	8080	18	13.956 KiB	6	10	984 bytes	8	12.995 KIB	9.341013	0.0847	90.791 KiB	1.199 MiB
192.168.1.180	59858	192.168.1.166	8080	18	14.570 KiB	7	10	1.575 KiB	8	12.995 KIB	9.425774	0.0065	1.907 MiB	15.733 MiB
192.168.1.180	59860	192.168.1.166	8080	16	13.717 KiB	8	9	805 bytes	7	12.931 KIB	13.436945	0.0053	1.163 MiB	19.133 MiB
192.168.1.180	60218	192.168.1.166	8080	10	3.075 KiB	11	6	580 bytes	4	2.509 KIB	36.906801	0.0056	815.853 KiB	3.529 MiB

This way, we can take a higher-level approach to analyze the attack.

Solution

Finally, we see the conversation between the victim and the attacker. The attacker does some basic enumeration and persistence tactics and finally echoes a `base64` string into `rev` and then discards its output.

It turns out that if we pipe the output of `rev` into `base64 -d` will display the flag:

```
1 $ echo ==gC9FSI5tGMwA3cfRjd0o2Xz0GNjNjYfR3c1p2Xn5WMYBXnfRjd0o2eCRFS | rev | base64 -d
```